

Architektura Zero Trust - Januszex-POL

1. Struktura użytkowników (20 komputerów)

Biuro (10 komputerów) - pracownicy standardowi

- Dostęp w godzinach pracy (8:00-17:00)
- Limit IP: sieci firmowe
- Zasoby: File Server (dokumenty), App Server (aplikacje)
- Wymagana weryfikacja co 4 godziny

IT Administratorzy (3 komputery) - zespół administracyjny

- Dostęp 24/7 do wszystkich zasobów
- Wyjątek: nadal wymagana weryfikacja tożsamości
- Dostęp administracyjny wymaga Multi-Factor Authentication (MFA)
- Monitorowanie wszystkich działań w SIEM

Management (4 komputery) - kierownictwo

- Dostęp do wszystkich zasobów z dodatkowymi ograniczeniami
- Wymóg: weryfikacja dodatkowa (biometria/OTP) dla bazy danych
- Dostęp do wrażliwych raportów wymaga potwierdzenia
- Audyt wszystkich operacji

Remote (3 komputery) - pracownicy zdalni

- Obowiązkowe połączenie przez VPN Gateway
- Wymagane MFA dla każdej sesji
- Ograniczony czas sesji (8 godzin)
- Weryfikacja co 1 godzinę

2. Komponenty Zero Trust Control Plane

Policy Engine (Centrum decyzji dostępu)

- Sprawdza każde żądanie dostępu niezależnie
- Podejmuje decyzję:  ALLOW lub  DENY
- Bierze pod uwagę: tożsamość, kontekst, device posture, czas
- Loguje każdą decyzję do SIEM

Identity Server (Weryfikacja tożsamości)

- Integracja z Active Directory/LDAP
- Weryfikuje użytkownika przed każdym dostępem
- Sprawdza status konta (aktywne/zawieszone)

- Synchronizacja z systemem kadrowym

Monitor/SIEM (Obserwacja zagrożeń)

- Monitoruje wszystkie próby dostępu
 - Wykrywa anomalie (podejrzane IP, godziny, lokalizacje)
 - Alertuje o zagrożeniach w czasie rzeczywistym
 - Tworzy raporty do compliance
-

3. Chronione zasoby (3 serwery)

File Server - Dokumenty firmowe

- Dostęp: Biuro (pełny), Management (pełny), IT (pełny), Remote (limit)
- Szyfrowanie: AES-256
- Backup: codziennie

App Server - Aplikacje biznesowe

- Dostęp: wszyscy (zależnie od roli)
- Aplikacje: CRM, ERP, HR System
- Load balancing dla wydajności

DB Server - Baza danych

- Dostęp: Management (czytanie), IT (czytanie+zapis), Remote (brak)
 - Szyfrowanie transmisji: TLS 1.3
 - Query audit logging
-

4. Zabezpieczenia obwodowe

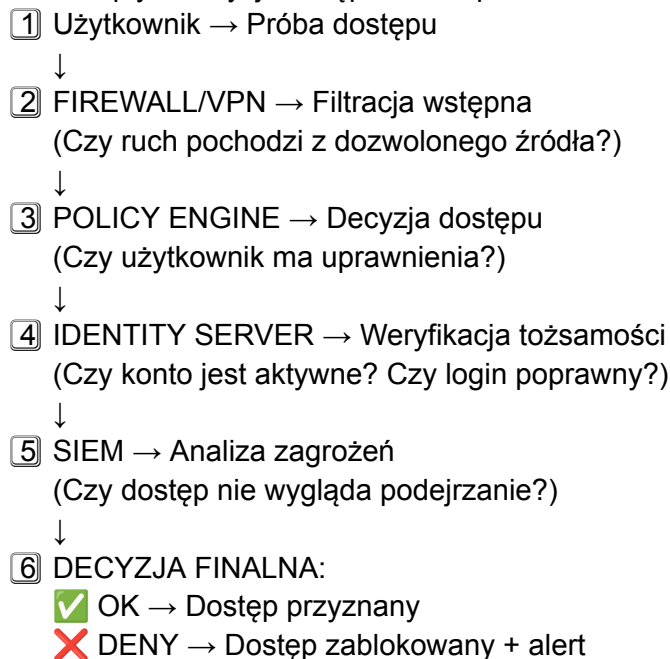
Firewall - Filtracja ruchu

- Blokuje podejrzany ruch (port scanning, DDoS)
- Implementuje IPS (Intrusion Prevention System)
- Loguje wszystkie próby
- Konfiguracja: whitelisty dla zasobów

VPN Gateway - Dla pracy zdalnej

- Protokół: WireGuard lub OpenVPN
- Szyfrowanie: 256-bit
- Autentykacja: certyfikat + hasło
- Rozdzielanie ruchu (split-tunneling disabled)

5. Przepływ decyzji dostępu - Krok po kroku



6. Zasady dla każdej grupy użytkowników

Grupa	Dostęp	Warunki	Monitoring
Biuro	File, App	Godziny robocze, IP sieci	Każda operacja
IT	ALL	24/7 + MFA	Szczegółowy audit
Management	ALL	+OTP dla DB, weryfikacja	Wszystkie akcje
Remote	File, App	VPN + MFA, max 8h	Co 1h weryfikacja

7. Scenariusze testowe

Scenariusz 1: Pracownik biuro chce dostęp do File Server o 9:00

- ✓ Policy Engine: OK (uprawnienia są)
- ✓ Identity: Konto aktywne
- ✓ SIEM: Normalny czas, znane IP
- 📁 **REZULTAT: DOSTĘP PRZYZNANY**

Scenariusz 2: Pracownik Remote chce dostęp o 2:00 w nocy bez VPN

- ✗ Policy Engine: Brak VPN
- ✗ SIEM: Anomalia czasowa
- 🚫 **REZULTAT: DOSTĘP ZABLOKOWANY + ALERT**

Scenariusz 3: Management potrzebuje dostęp do DB Server

-  Policy Engine: Uprawnienia OK
-  Identity: Konto OK
-  Wymóg: Dodatkowa weryfikacja OTP
-  **REZULTAT: DOSTĘP PO OTP + PEŁNY AUDIT**